



2016 中国互联网安全大会
China Internet Security Conference

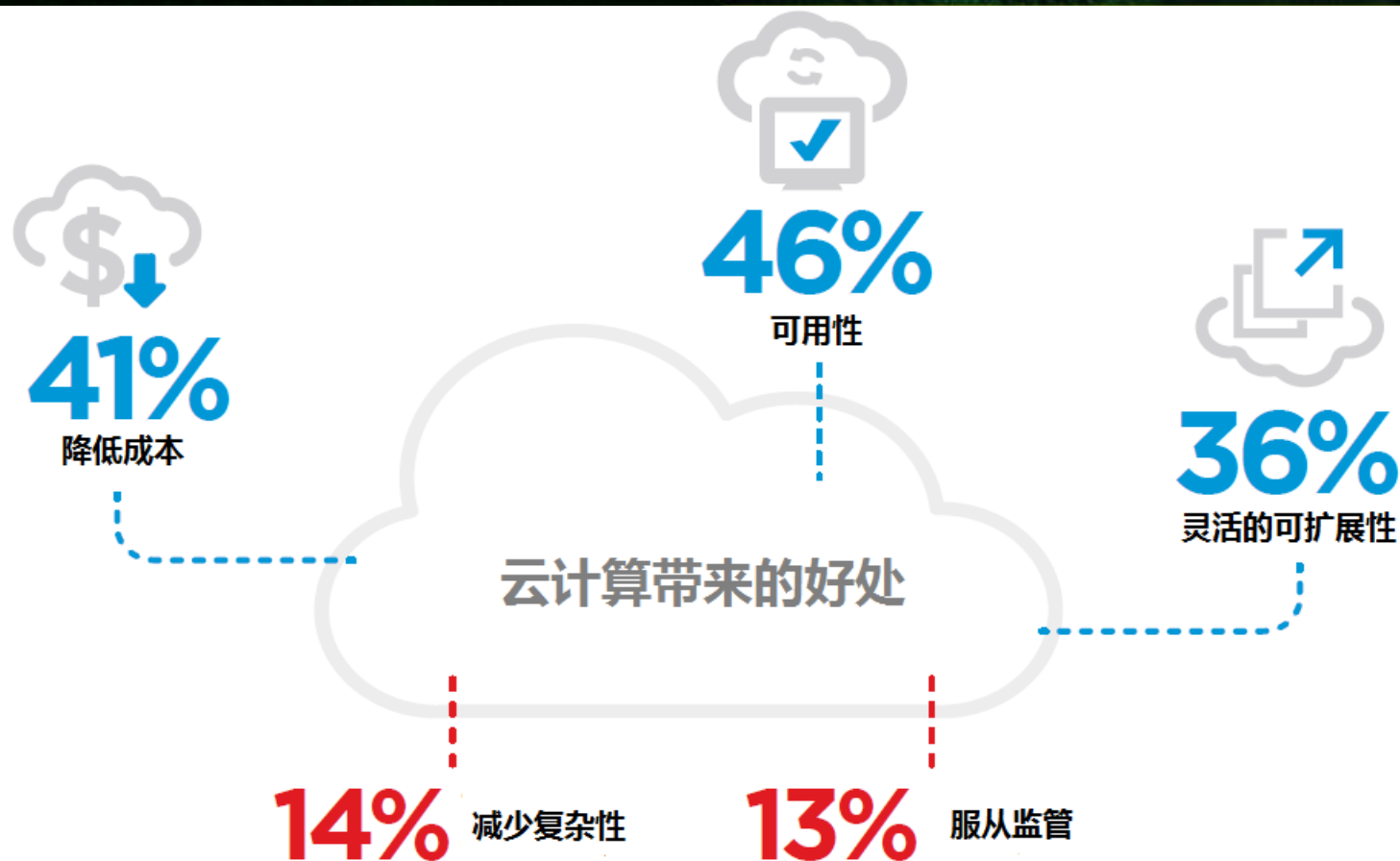
协同联动 共建安全+命运共同体

基于真实应用的大数据仿真和云安全测试

曲 博

思博伦通信
亚太区业务拓展高级经理

云计算带来的好处



开销从固定资本支出（购买）变为运营支出（租赁/订阅服务）：32% | 加速部署和配置：31% | 增加灵活性：28% | 提高性能：27% | 提高效率：26% | 增加地理覆盖：24% | 提高员工生产力：23% | 提高安全性：19% | 加速上市时间：18% | 不确定/其它：25%

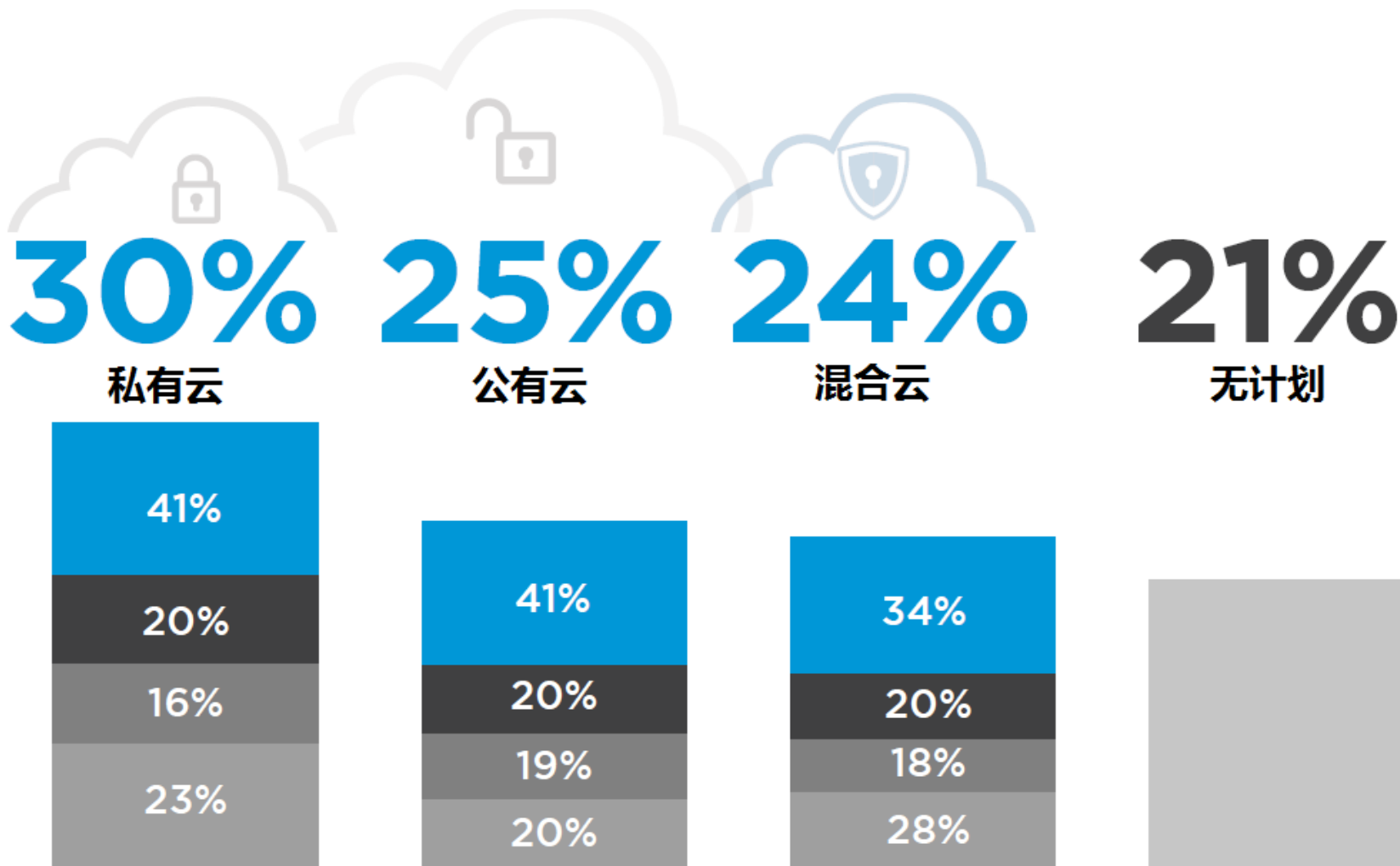
云部署阶段



中国互联网安全大会

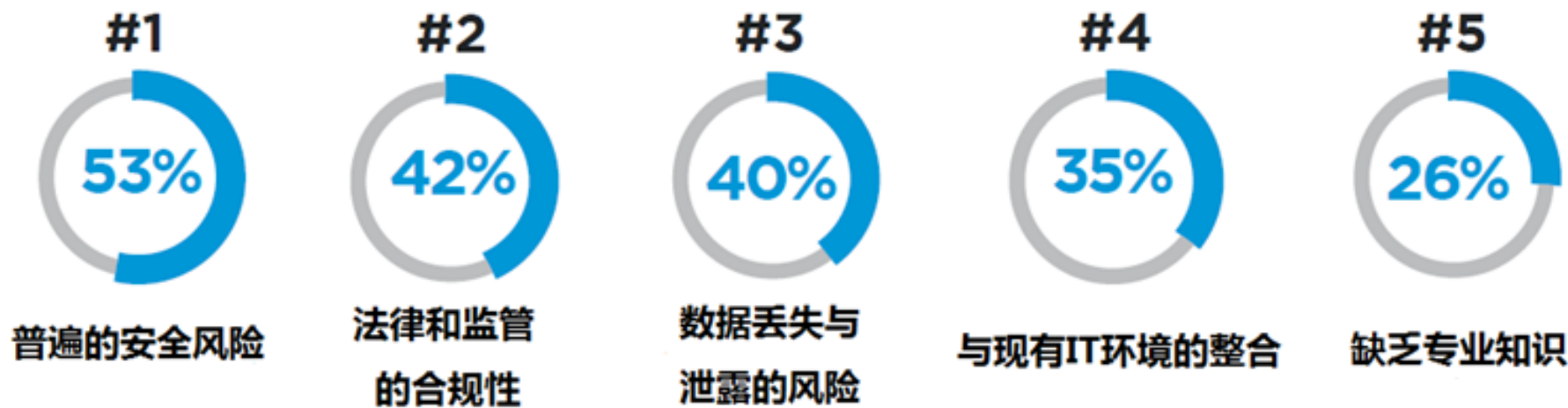


360互联网安全中心



源自：Linkedin信息安全组云安全焦点报告（2016）

部署云过程中面临的问题

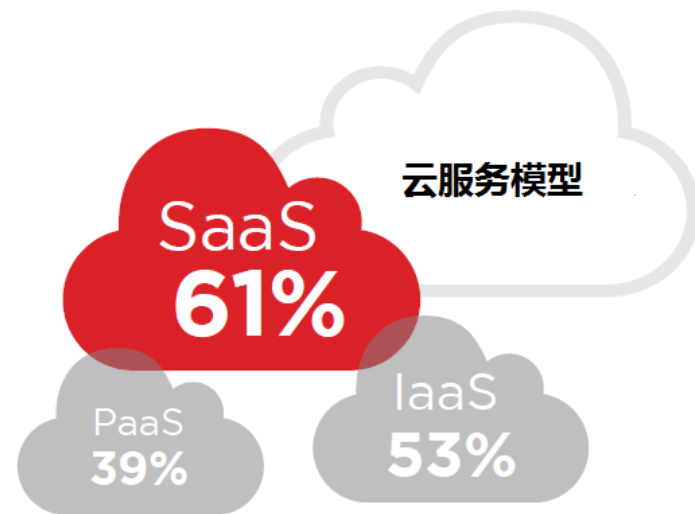


失去控制：23% | 管理复杂度：20% | 厂商锁定的担忧：18% | 内部阻力和惰性：18% |
缺乏员工资源：17% | 缺乏透明度和能见度：15% | 缺乏云服务模式的成熟度：14% |
成本/缺乏投资回报：13% | 预算不足：13% | 云应用的性能：12% | 缺乏管理层参与：10% |
缺乏可定制性：9% | 对云服务/性能/定价不满意：7% | 计费 and 跟踪问题：7% |
缺乏云提供商的支持：6% | 可用性：5% | 不确定/其它：10%

源自：Linkedin信息安全组云安全焦点报告（2016）

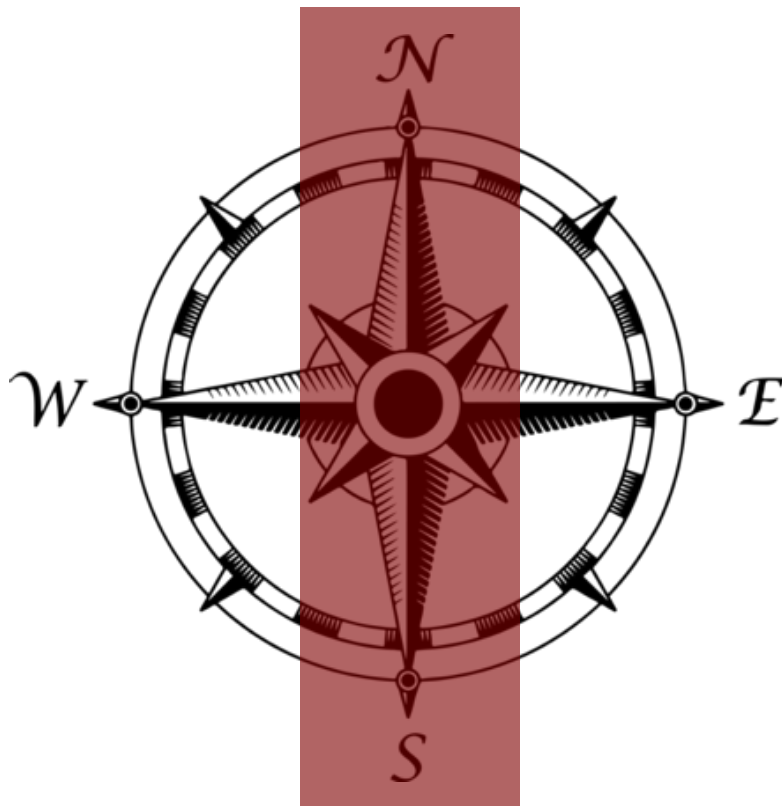
如何解决云部署过程中的问题？

- 云服务提供商
 - 解决部署云过程中面临的问题
 - 如何吸引企业购买云服务
- 企业
 - 了解部署云时应如何评估安全风险
 - 选择相应的安全产品
- 思博伦通信
 - 使用专业的基于云的测试服务解决方案，为独立专业的第三方云安全评测提供了具体的解决方案
 - 云架构测试
 - 基于真实应用的大数据仿真
 - 云安全测试



北/南（纵向）流量

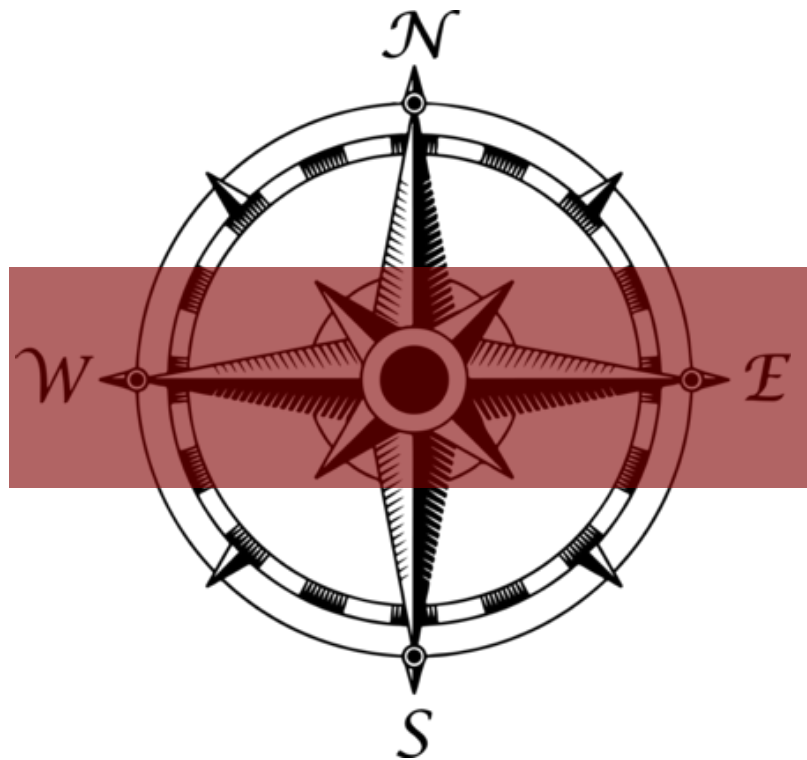
- 从外部进入到虚拟化环境的流量
- 该流量可能或者不可能通过其它物理安全设备
- 对面向公众的应用程序和服务进行访问限制
 - 仅允许访问所需的协议/端口
- 对进入的请求进行安全风险检查，并阻止任何恶意流量
- 对恶意流量进行报警



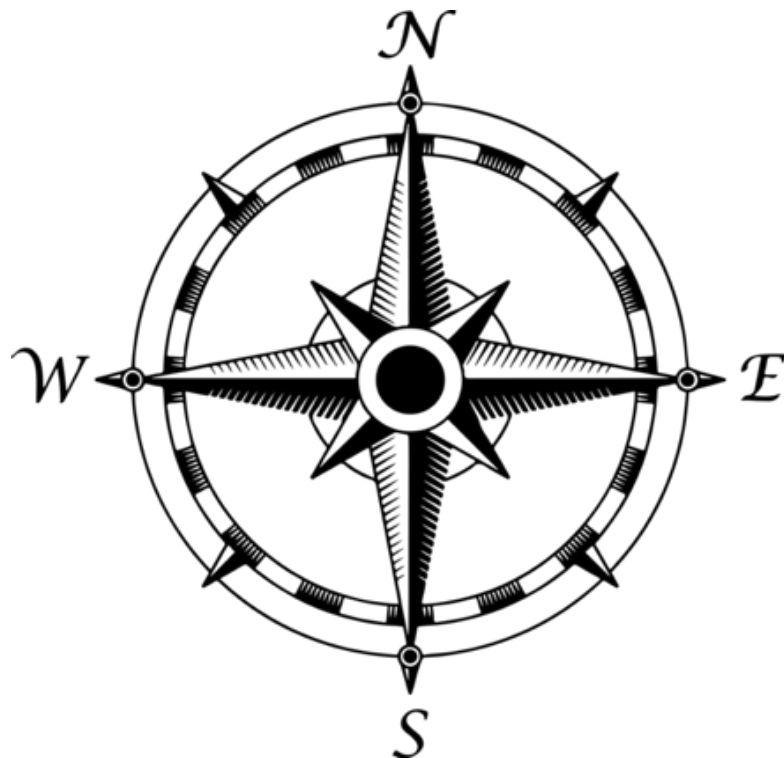
无边界基础架构所带来的挑战

东/西（横向）流量

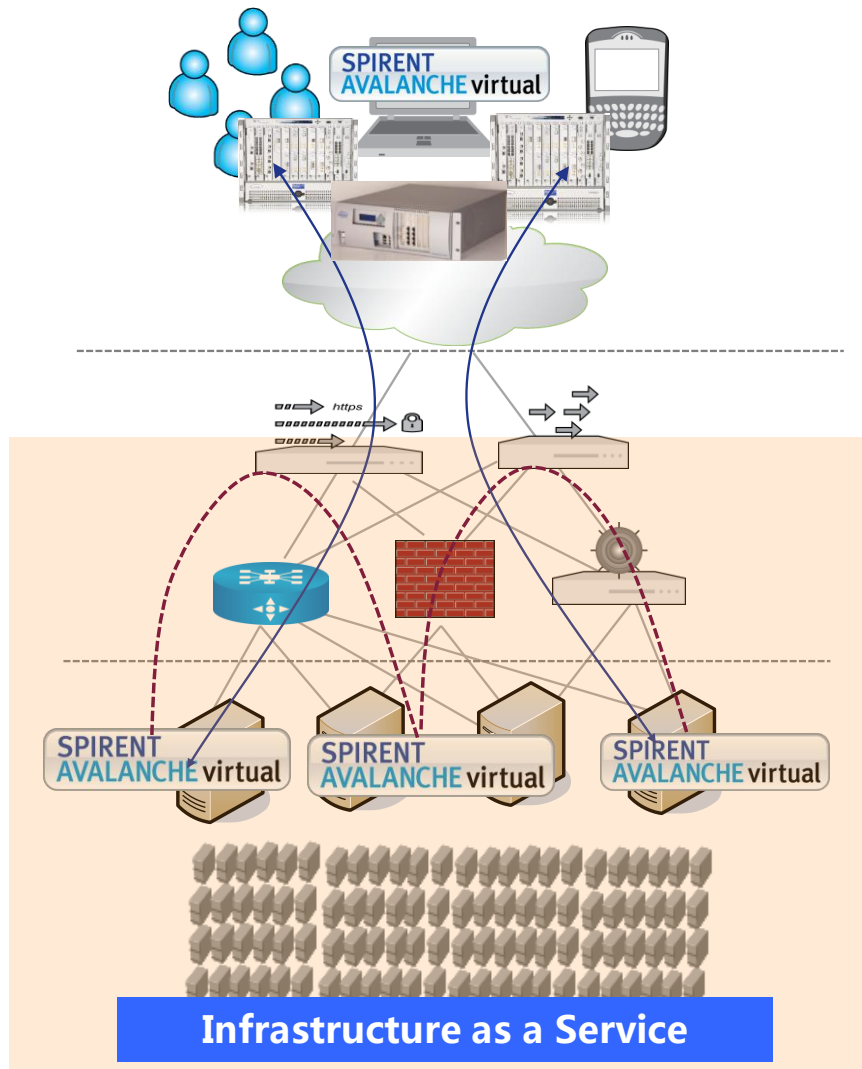
- 不同端口组或者安全区域中虚拟机之间的通信
- 虚拟机可以位于同一虚拟主机或者不同的虚拟主机上
- 限制可在各安全区域间进行通信的应用程序和服务
- 确认该流量是实际的应用流量
- 对该流量进行安全风险检查



- 确认仅允许通过进入受保护区域的流量
- 确认不允许的流量，无论是被策略限制，还是恶意流量，都被阻止进入受保护区域
- 测量不同类型策略所带来的影响
 - 到第一个字节的时间
 - 部署中服务质量的影响
- 测试由管理程序（Hypervisor）部署所带来的性能影响
 - Hypervisor的配置
 - 不同的Hypervisor



云基础架构测试 – IaaS

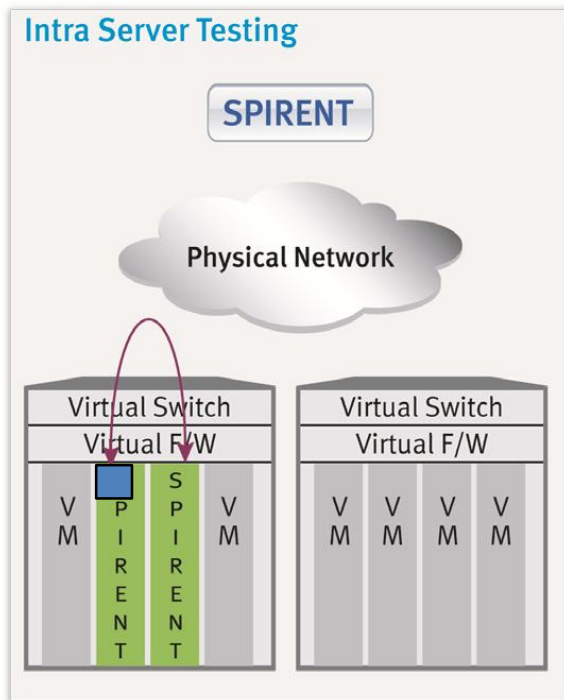


虚拟防火墙能够确保软件感染和恶意软件不会从一个虚拟机扩散到其它虚拟机吗？

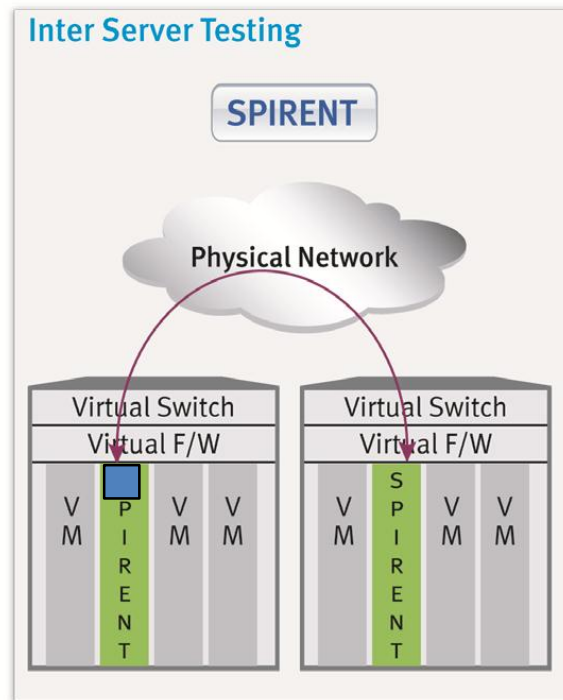
虚拟负载均衡能够提供虚拟应用所需要的完全可用性和最大性能吗？

虚拟设备平台可以达到线速吗？

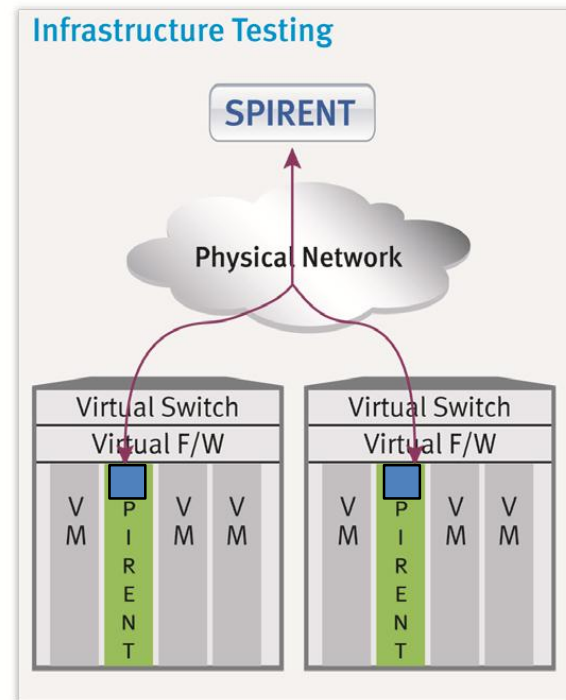
刀片服务器如何有效地支持多种应用？需要多少内存？



Virtual Port to Virtual Port



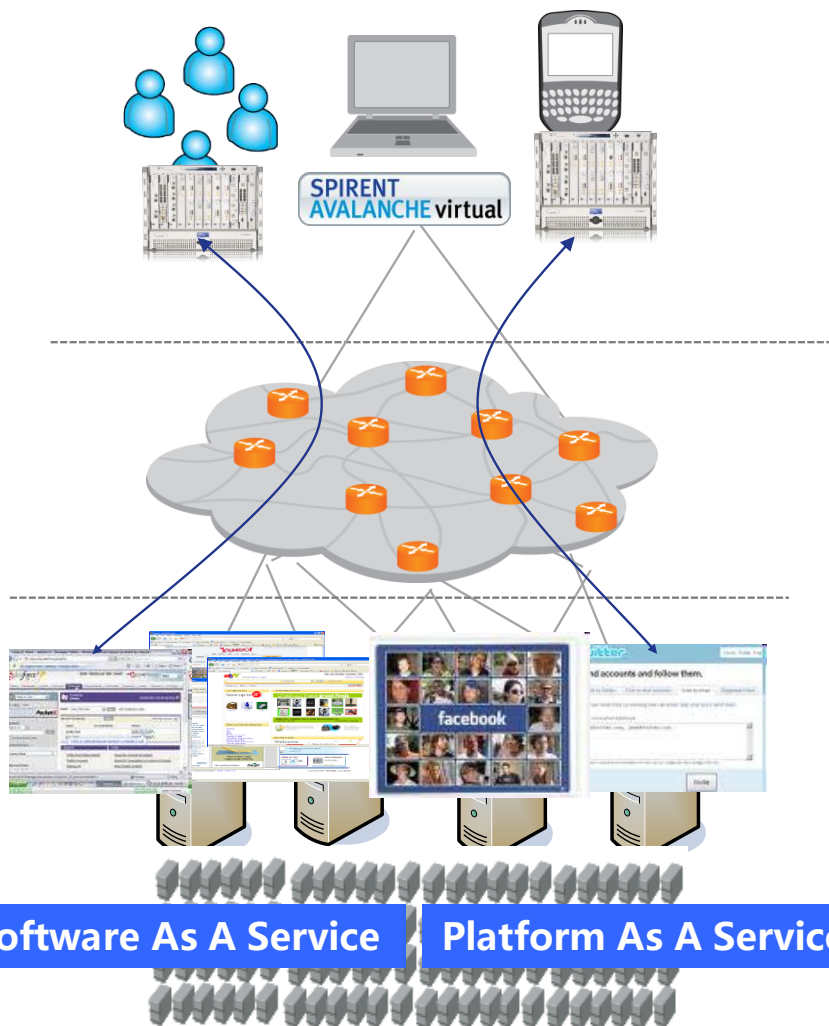
Virtual Port to Virtual Port
Across Virtual Switches



Virtual Port to any Physical Port

- 云应用和安全测试方案：Virtual
- 三种测试模式：虚拟端口到虚拟端口、跨虚拟交换机间的虚拟端口、虚拟端口到物理端口

云应用与安全测试 – SaaS和PaaS



如何将多个云服务平台合并？

云平台有效地维持线性扩展，并且承载基于需要的负载吗？

业务如何确保那些云网络中可能的敏感信息是安全的？

现有应用在不做重新设计的前提下，可以被部署在云网络中吗？

高可用性应用，如何保障持久性和容错性？

如何保障云安全？

最流行的云应用



- 最流行的云应用分类

- Web应用
- 通信类应用
- 提高生产率类应用
- IT运维应用
- 定制化业务应用
- 应用开发/测试
- 销售&市场
- HR应用
- 商业智能/分析应用
- 灾难恢复/存储/归档应用
- 内容管理应用
- 财会应用
- 供应链管理应用
- ...

当前部署

未来部署

41%	-----	Microsoft Office 365	-----	20%
27%	-----	Salesforce	-----	7%
24%	-----	Exchange	-----	11%
20%	-----	Google Apps	-----	6%
17%	-----	Dropbox	-----	5%
15%	-----	Service Now	-----	5%
14%	-----	Box	-----	4%
9%	-----	Workday	-----	4%
8%	-----	None	-----	5%
7%	-----	SuccessFactors	-----	3%
6%	-----	Not sure	-----	10%

源自：Linkedin信息安全组云安全焦点报告（2016）

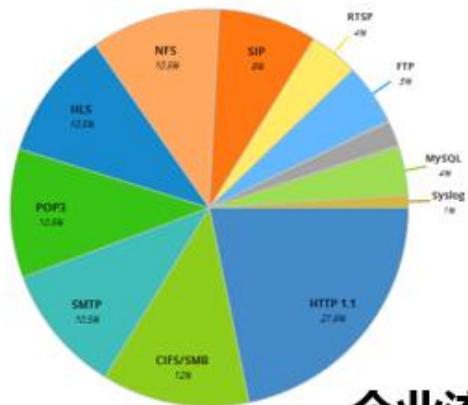
基于真实应用的大数据仿真 – TestCloud



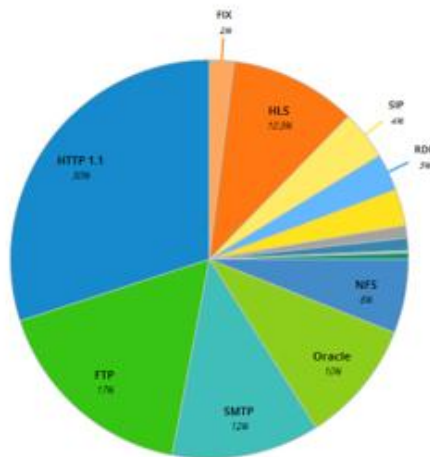
中国互联网络安全大会



360互联网安全中心



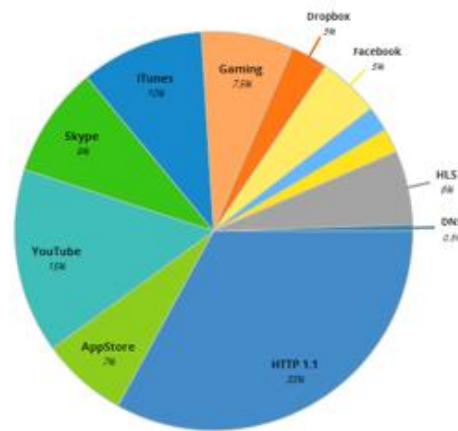
企业流量



金融流量

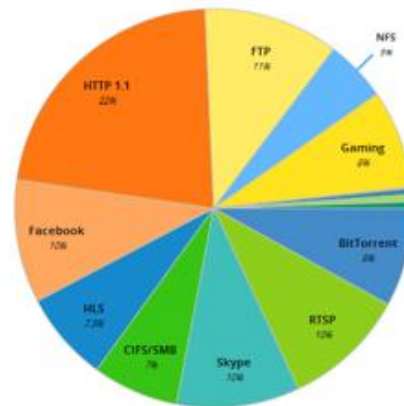
Protocols (8) / Apps (6)	
HTTP 1.1	21.80 %
CIFS/SMB	12.00 %
SMTP	10.50 %
POP3	10.50 %
HLS	10.50 %
NFS	10.50 %
SIP	8.00 %
RTSP	4.00 %
FTP	5.00 %
SSH	0.10 %
WebEx	2.00 %
RPC	0.10 %
MySQL	4.00 %
Syslog	1.00 %
Total 100 %	

Protocols (8) / Apps (7)	
NFS	6.00 %
Oracle	10.00 %
SMTP	12.00 %
FTP	17.00 %
HTTP 1.1	30.00 %
FIX	2.00 %
HLS	10.30 %
SIP	4.00 %
RDP	3.00 %
POP3	3.00 %
SSH	1.00 %
Syslog	1.00 %
DNS	0.10 %
NTP	0.10 %
Telnet	0.50 %



移动流量

Protocols (3) / Apps (9)	
HTTP 1.1	33.00 %
AppStore	7.00 %
YouTube	15.00 %
Skype	9.00 %
iTunes	10.00 %
Gaming	7.50 %
Dropbox	3.00 %
Facebook	5.00 %
Pandora	2.00 %
Twitter	2.00 %
HLS	6.00 %
DNS	0.50 %
Total 100 %	



高校流量

Protocols (7) / Apps (8)	
BitTorrent	8.00 %
RTSP	10.00 %
Skype	10.00 %
CIFS/SMB	7.00 %
HLS	7.30 %
Facebook	10.00 %
HTTP 1.1	22.00 %
FTP	11.00 %
NFS	5.00 %
Gaming	8.00 %
DNS	0.10 %
SNMP	0.50 %
Telnet	0.50 %
NTP	0.10 %
SSH	0.50 %

基于真实应用的大数据仿真 – TestCloud



中国互联网安全大会



360互联网安全中心

- 每一种场景仿真都来自真实数据
- 应用的不同版本
- 多种系统平台
- 多种手机平台
- 丰富的应用场景
- 动态生成交互流程图
- 可以修改场景内容
- 可以加入自定义的场景
- 支持内容通过变量动态替换

cyberflood

CALLFLOW: WeChat : Login, send file and logout (01)

Print

Summary

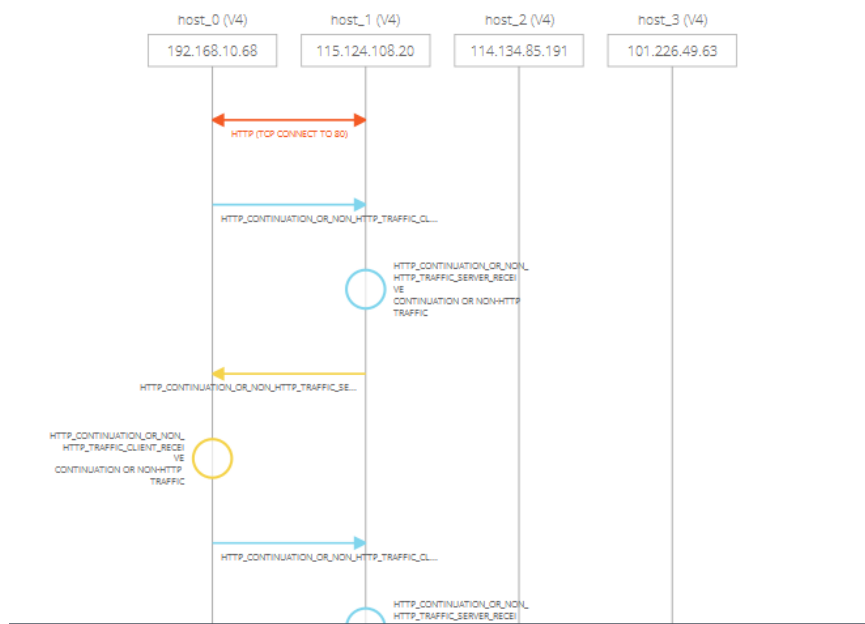
ID: 02.2013.04.communication.wechat.play_google_com.wechat.login_send_file_logout-01

Description: This scenario contains user-initiated operations of WeChat on an Android smartphone. The user logs on to WeChat, selects a friend, sends a file and logs out.

Category: Communication

Hosts: 4

Steps: 177



公有云最大的安全威胁

#1



53%

未授权访问

#2



44%

盗用帐户

#3



39%

不安全的接口/API

#4

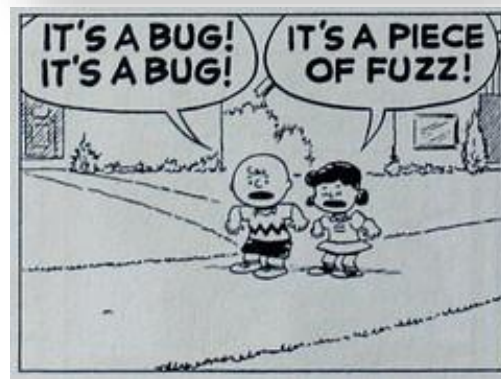


33%

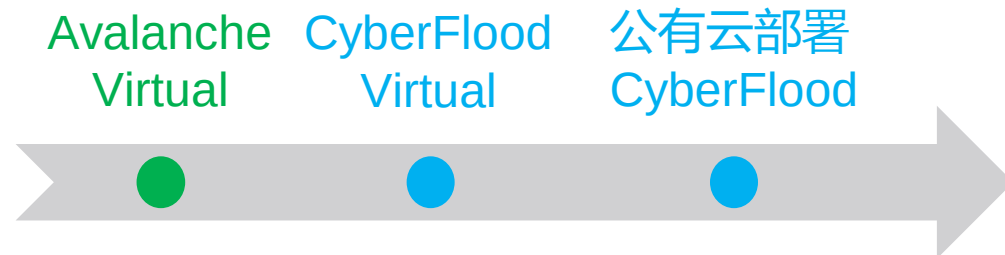
数据的外部共享

员工保密的专有数据泄密：33% | 恶意的内部人员：32% | 拒绝服务攻击：31%
外国赞助的网络攻击：30% | 恶意软件注入：25% | 云服务的滥用：24% |
共享内存攻击：18% | 威胁的横向移动（东-西流量，虚机与虚机之间）：16% |
服务窃取：15% | 丢失移动设备：12% | 自然灾害：5% | 不确定/其它：9%

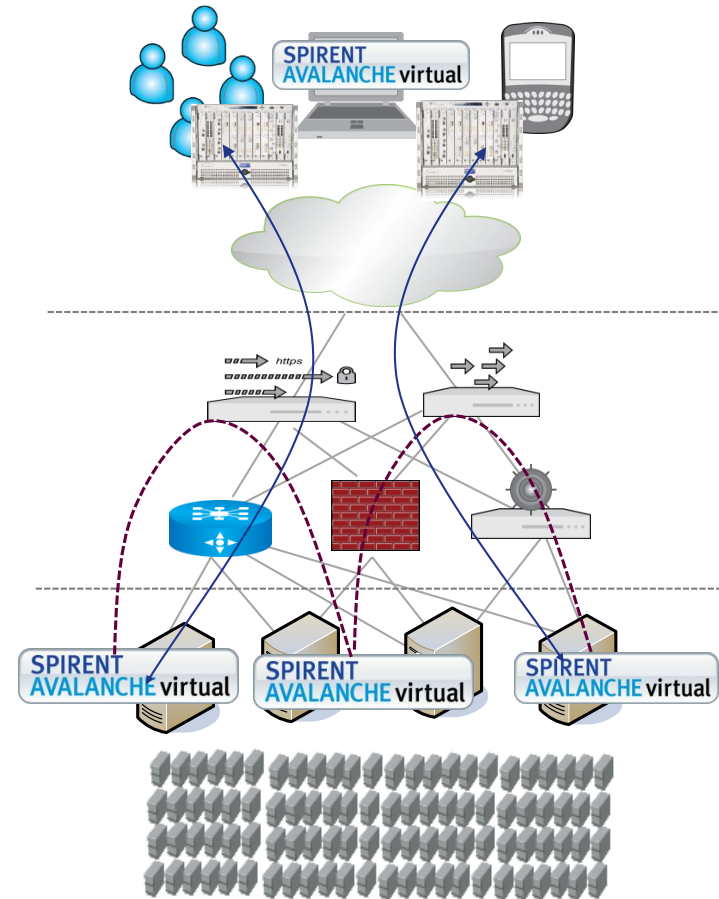
- DDoS攻击和应用混合测试
 - Volumetric DDoS、协议层DDoS、应用层DDoS、混合DDoS...
 - ARPFlood, TearDrop, SYN Flood, UDP Flood, XmasTree, R.U.D.Y., HTTP GET Floods...
- 攻击和漏洞利用：操作系统漏洞、软件漏洞、SQL注入、跨站攻击、目录遍历、缓冲区溢出等
- 恶意软件攻击：僵尸、蠕虫、木马
- 未知的恶意软件，针对二代防火墙和APT攻击
- 协议模糊测试（Fuzzing）
- 单臂攻击测试
- 定制化攻击场景模拟
- HTTPs流量加密
- 以上场景的组合



- PASS测试解决方案
 - 云性能测试 (Performance)
 - 云可用性测试 (Availability)
 - 云安全测试 (Security)
 - 云可扩展性测试 (Scalability)
 - 不同Hypervisor的性能测试
- 关键特性
 - 客户端/服务器
 - 用户真实性/应用真实性
 - 攻击仿真
 - 测试过程中调整负载
 - 详细的统计分析



- Virtual
 - 支持在VMware ESXi上部署
- Virtual Anywhere
 - 可被部署到Linux虚拟机的独立程序
 - 基于Red Hat 的Linux虚拟机支持
 - Red Hat ES、Fedora、CentOS
 - 可运行在任何支持Linux的Hypervisor上
 - VMware ESXi
 - KVM
 - QEMU
 - Xen
 - HyperV
- 基于公有云的CyberFlood
 - Amazon AWS、Microsoft Azure...



- 具有丰富经验的安全专家团队提供全面的安全服务

- 漏洞扫描服务
- 渗透测试服务（模拟黑客入侵行为，进一步评估被测系统的安全问题）



- 对云架构进行全面测试
 - 公有云、私有云、混合云
 - 纵向、横向测试：虚机与外部的通信、虚机之间的通信
 - IaaS、PaaS、SaaS
- 云性能测试
 - 云基础架构性能测试
 - 基于真实应用的大数据仿真
 - 基于真实应用仿真下的性能评估
- 云安全测试
 - 各种攻击仿真测试：DDoS、漏洞利用、恶意软件、模糊攻击...
 - 安全评估服务、渗透性测试服务

谢 谢



中国互联网安全大会



360互联网安全中心